TechSecure Solutions: NIST CSF 2.0 Maturity Assessment

Fictional organisation | Self-directed training project | Martin Paul Searle | October 2026

This is a training exercise. TechSecure Solutions, its staff, systems and the evidence described below are invented to practise applying the NIST Cybersecurity Framework. Scores are illustrative judgements made against simulated evidence, not findings from a real organisation.

1. Summary

TechSecure Solutions is a fictional US-based provider of cloud services to small businesses, with about 120 staff. This assessment scores its cybersecurity programme against all six functions of NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover) and sets a target profile.

Overall current maturity: 2.3 out of 5. Target: 3.5. Gap: 1.2.

TechSecure's technical protection (Protect, 2.8) is its strongest area, while governance, detection and incident response are weakest. The main pattern is a gap between policy and practice: TechSecure's own Cybersecurity Policy requires a SIEM, annual training and a tested incident response plan, and none of these is operating as written. The policy also says nothing about supplier risk, so supply chain risk management is the lowest-scoring category (1) and the highest priority gap, given that TechSecure relies on cloud and third-party providers.

Function	Current	Target	Gap
Govern (GV)	2.2	3.7	1.5
Identify (ID)	2.3	3.7	1.4
Protect (PR)	2.8	3.6	0.8
Detect (DE)	2.0	3.5	1.5
Respond (RS)	2.0	3.3	1.3
Recover (RC)	2.5	3.5	1.0
Overall	**2.3**	**3.5**	**1.2**

2. Scope and method

Scope: TechSecure's corporate IT, cloud hosting platform, customer data and employee processes.

Framework: NIST Cybersecurity Framework 2.0 (February 2024), scored at category level. The six functions are used, including Govern, which was added in version 2.0.

Maturity scale (1 to 5). This is a simple scale used for this exercise. It is separate from the CSF's own Implementation Tiers.

1. **Initial:** ad hoc, undocumented, depends on individuals
2. **Developing:** some practices exist but are informal or inconsistent
3. **Defined:** documented, approved and generally followed
4. **Managed:** measured, monitored and reviewed regularly
5. **Optimised:** continuously improved using metrics and lessons learned

Evidence: TechSecure's own Cybersecurity Policy (written against CSF 1.1) is the baseline. Each category compares what the policy requires with simulated evidence of what actually operates, drawn from invented document reviews and staff interviews.

Target profile: set at 3 or 4 per category, based on a small cloud provider handling customer data. A target of 5 everywhere would be unrealistic and costly for a firm this size.

Limitations: the evidence is fictional, so the scores show how the method is applied, not real security posture. No technical testing was performed.

3. Findings by function

Govern (GV): average 2.2

- **GV.OC Organisational Context: 3 (target 4).** *Policy requires:* cybersecurity activities aligned with business objectives and regulatory requirements. *Evidence:* the business strategy names customer data protection as a priority and customer contracts list security and privacy obligations. *Reasoning:* the context is documented and understood, so a 3. It does not yet feed into risk decisions or reporting, which keeps it from a 4.
- **GV.RM Risk Management Strategy: 2 (target 4).** *Policy requires:* annual risk assessments, but sets no risk appetite or method. *Evidence:* risk is discussed in management meetings with no agreed appetite or approach. *Reasoning:* practices exist but are informal. A 4 needs a defined appetite and regular review.
- **GV.RR Roles and Responsibilities: 2 (target 4).** *Policy requires:* a Cybersecurity Officer, an IT Security Team, and defined duties for staff and management. *Evidence:* the Cybersecurity Officer post is unfilled, the IT manager covers it informally, and there is no board-level owner. *Reasoning:* the roles are well defined on paper but accountability depends on one person in practice.
- **GV.PO Policy: 3 (target 4).** *Policy requires:* mandatory compliance for all staff and systems. *Evidence:* the policy exists and is approved, but it is reviewed only when something changes and is written against CSF 1.1. *Reasoning:* documented and approved, which meets a 3. A scheduled review against CSF 2.0 would move it to a 4.
- **GV.OV Oversight: 2 (target 3).** *Policy requires:* quarterly audits to verify compliance. *Evidence:* no audits have been held, and leadership receives only ad hoc incident updates. *Reasoning:* oversight is stated but not carried out.
- **GV.SC Supply Chain Risk Management: 1 (target 3).** *Policy requires:* nothing on suppliers. *Evidence:* no supplier inventory by risk, no security clauses in most supplier contracts, and no due diligence before onboarding vendors. *Reasoning:* a cloud provider depends heavily on third parties, so the absence of any requirement or process is the largest governance gap.

Identify (ID): average 2.3

- **ID.AM Asset Management: 3 (target 4).** *Policy requires:* all IT assets in a central register, updated quarterly. *Evidence:* a spreadsheet inventory exists, but it is updated irregularly and software and data assets are incomplete. *Reasoning:* documented and used, but coverage and update frequency fall short of the policy.
- **ID.RA Risk Assessment: 2 (target 4).** *Policy requires:* annual risk assessments reported to the Cybersecurity Officer. *Evidence:* one assessment was done two years ago and has not been repeated. *Reasoning:* the practice happened once but is not repeated, so a 2.
- **ID.IM Improvement: 2 (target 3).** *Policy requires:* lessons learned from incidents built into updated policies and plans. *Evidence:* lessons are discussed informally but not recorded or tracked to completion. *Reasoning:* improvement happens, without evidence of follow-through.

Protect (PR): average 2.8

- **PR.AA Identity Management, Authentication and Access Control: 3 (target 4).** *Policy requires:* role-based access control and multi-factor authentication on all systems handling sensitive data. *Evidence:* role-based access is in place and MFA is enforced for administrators and cloud consoles, but not yet on every system, and access reviews are not scheduled. *Reasoning:* strong controls that are defined and mostly followed, with a few systems and no review cycle holding it below a 4.
- **PR.AT Awareness and Training: 2 (target 3).** *Policy requires:* annual training on phishing, passwords and incident reporting. *Evidence:* staff receive one induction session, with no refresher or phishing exercises. *Reasoning:* the policy requirement is not being met.

- **PR.DS Data Security: 3 (target 4).** *Policy requires:* AES-256 at rest, TLS 1.3 in transit and offsite backups. *Evidence:* customer data is encrypted as required and backups are encrypted offsite, but data classification is informal. *Reasoning:* the key technical controls operate as written, but classification and retention rules are not formal.
- **PR.PS Platform Security: 3 (target 4).** *Policy requires:* firewalls restricting traffic to authorised ports and VPN with MFA for remote access. *Evidence:* firewall rules follow the policy and servers are built from hardened images and patched monthly, but exceptions are not tracked. *Reasoning:* a defined routine without measurement.
- **PR.IR Technology Infrastructure Resilience: 3 (target 3).** *Evidence:* the platform runs across two availability zones with documented failover. *Reasoning:* meets the target, so no gap.

Detect (DE): average 2.0

- **DE.CM Continuous Monitoring: 2 (target 4).** *Policy requires:* a SIEM monitoring all network traffic and access to sensitive systems, plus monthly vulnerability scans with critical findings fixed within 30 days. *Evidence:* no SIEM has been deployed, cloud logs are collected but not correlated, nobody reviews alerts outside office hours, and scans run irregularly. *Reasoning:* the policy's central monitoring control does not exist in practice. For a 24/7 service this is a priority gap.
- **DE.AE Adverse Event Analysis: 2 (target 3).** *Policy requires:* IDS/IPS configured to alert on suspicious activity. *Evidence:* an intrusion detection system runs at the perimeter, but alerts are not triaged and there are no severity levels. *Reasoning:* the tool exists, but analysis is reactive and inconsistent.

Respond (RS): average 2.0

- **RS.MA Incident Management: 2 (target 4).** *Policy requires:* an incident response plan with defined roles, tested through tabletop exercises twice a year. *Evidence:* a plan was drafted but has never been tested, and roles are unclear. *Reasoning:* a plan that has never been exercised cannot be assumed to work.
- **RS.AN Incident Analysis: 2 (target 3).** *Policy requires:* documented root cause analysis. *Evidence:* root causes are sometimes recorded, with no standard template. *Reasoning:* informal.
- **RS.CO Incident Response Reporting and Communication: 2 (target 3).** *Policy requires:* incidents reported to stakeholders within 72 hours. *Evidence:* there is no defined process or owner for notifying customers or regulators. *Reasoning:* without a process, the 72-hour requirement cannot be met reliably.
- **RS.MI Incident Mitigation: 2 (target 3).** *Policy requires:* prompt containment and eradication of threats. *Evidence:* containment steps are known by the technical team but not documented. *Reasoning:* knowledge sits with individuals.

Recover (RC): average 2.5

- **RC.RP Incident Recovery Plan Execution: 3 (target 4).** *Policy requires:* documented disaster recovery plans tested annually, and backups tested quarterly. *Evidence:* the recovery plan is documented and restore times are recorded, but backups are tested twice a year rather than quarterly. *Reasoning:* defined and tested, but below the frequency the policy sets.
- **RC.CO Incident Recovery Communication: 2 (target 3).** *Evidence:* no template or owner for updating customers during an outage. *Reasoning:* informal and dependent on individuals.

4. Priority gaps and recommendations

Priorities are ranked by size of gap and risk to the business.

1. **Supply chain risk (GV.SC, 1 to 3).** Add supplier requirements to the policy, build a supplier inventory ranked by risk, add security clauses to contracts, and require due diligence for new vendors. *Why first:* a failure at a cloud or software supplier directly affects customers, and the policy is silent on it.
2. **Risk management (GV.RM and ID.RA, 2 to 4).** Define a risk appetite, adopt a risk register, and carry out the annual risk assessment the policy already requires. *Why:* every other control decision depends on a current view of risk.

3. **Monitoring and detection (DE.CM and DE.AE, 2 to 4 and 3).** Deploy the SIEM the policy requires, define alert triage, and arrange out-of-hours coverage. *Why:* TechSecure is a 24/7 service, and late detection increases damage and notification obligations.
4. **Roles and oversight (GV.RR and GV.OV, 2 to 4 and 3).** Formally appoint the Cybersecurity Officer the policy describes, with a role description and a board sponsor, and start the quarterly compliance audits.
5. **Incident response (RS.MA and RS.CO, 2 to 4 and 3).** Run the tabletop exercise the policy requires, assign roles, and add customer and regulator notification steps to meet the 72-hour commitment.
6. **Awareness training (PR.AT, 2 to 3).** Deliver the annual training and phishing simulations the policy already requires.

5. Proposed roadmap

- **0 to 3 months:** appoint the Cybersecurity Officer, build the supplier inventory, draft the risk appetite, run the first incident tabletop exercise.
- **3 to 6 months:** repeat the risk assessment, add supplier clauses to contracts and the policy, introduce alert triage and a severity scale, hold the first quarterly compliance audit.
- **6 to 12 months:** deploy the SIEM with out-of-hours monitoring, scheduled access reviews, annual training, update the policy to CSF 2.0, and reassess against this target profile.

6. Reflections

- A maturity score is a judgement, not a measurement. Different assessors could reasonably score some categories one point higher or lower, so the written reasoning matters more than the number.
- Comparing practice with policy is a useful way to assess a programme. A good policy does not mean the controls operate, and the largest gaps here sit between what the policy says and what happens.
- The policy was written against CSF 1.1, so it has no Govern function and no supplier requirements. Updating it to CSF 2.0 is a natural next step.
- Fictional evidence limits how much can be concluded. A real assessment would test evidence by sampling records, checking configurations and interviewing more than one person per area.